Audit de sécurité - Plateforme Code un max

1. Définition de la Triade CIA appliquée à la plateforme Code un max

Confidentialité : Permet d'assurer que seules les personnes autorisées peuvent accéder au contenus. **Intégrité** : Permet de garantir que le contenu ne peut pas être modifiés ou corrompus de manière non autorisée. **Disponibilité** : Permet de s'assurer que le contenu reste acessible en toute circonstance sans interruption majeur.

2. Différence entre menace, vulnérabilité, risque et exploit

Menace : Une menace peut être un acteur ou un événement potentiel susceptible d'exploiter une faille pour nuire au système. **Vulnérabilité** : C'est une faiblesse ou un défaut dans la conception, dans du code ou la configuration d'un système. **Risque** : C'est la probalité qu'une menace exploite une vulnérabilité, combiné à l'impact que cela pourrait engendrer sur une entreprise. **Exploit** : C'est un code ou une technique concrète utilisée pour exploiter une vulnérabilité.

3. Surface d'attaque du lab

Réseau et Hôte : Le lab repose sur un réseau virtuel de type bridge (`cyberlab-net` en `10.40.0.0/16`) interconnectant deux conteneurs :

- La cible : `dvwa-cible` avec l'adresse ip `10.40.0.10` qui héberge l'application web vulnérable
- L'attaquant: `attaquant` avec l'adresse ip `10.40.0.20` configuré pour effectuer les tests avec différents outils Le point d'entrée est l'interface web HTTP de l'application web DVWA, qui est accessible depuis le réseau interne du lab

4. Bonus

Responsabilité partagée

La plateforme Code un max est hébergé dans le Cloud, la sécurité est répartie selon deux axes :

- Ce qui relève du **fournisseur** : La sécurité physique des datacenters, des hôtes de virtualisation et de l'infrastructure réseau globale.
- ce qui relèbve de l'**entreprise** : La configuration des applications, la gestions des identités et des accès (IAM), l'application des correctifs sur les services déployés.

Chiffrement et Hachage

Chiffrement symétrique : Utilise une seule et unique clé partagée pour chiffrer et déchiffrer les données **Chiffrement asymétrique** : Utilise une paire de clés mathématiquement liées (une clé publique pour chiffrer et une clé privée pour déchiffrer). **Hachage et salage** : Le hachage et la transformation irréversible d'une donnée à laquelle on ajoute une chaine de caractères aléatoire (le sel) avant le hachage pour empêcher l'utilisation de table de correspondance particulière.

5. Docker Compose

```
networks:
  cyberlab-net:
    driver: bridge
    ipam:
      config:
        - subnet: 10.40.0.0/16

services:
  dvwa-cible:
    image: vulnerables/web-dvwa
    container_name: dvwa-cible
    networks:
      cyberlab-net:
        ipv4_address: 10.40.0.10

  attaquant:
    image: debian:12
    container_name: attaquant
    networks:
      cyberlab-net:
        ipv4_address: 10.40.0.20
    cap_add:
      - NET_ADMIN
      - NET_RAW
    command: sleep infinity
    volumes:
      - .:/data
```

5.1 Bon fonctionnement de la stack

```
docker compose ps
```

```
brandon@debian:~/cybersec-audit-codemax$ docker compose ps
WARN[0000] /home/brandon/cybersec-audit-codemax/docker-compose.yml: the attribute `version` is obsolete, it will be ignored, please remove it to avoid potential confusion
NAME          IMAGE                 COMMAND           SERVICE       CREATED             STATUS         PORTS
attaquant     debian:12             "sleep infinity"  attaquant     About an hour ago   Up 3 minutes
dvwa-cible    vulnerables/web-dvwa  "/main.sh"        dvwa-cible    About an hour ago   Up 3 minutes   80/tcp
brandon@debian:~/cybersec-audit-codemax$
```

6. Installation des outils dans la machine de l'attaquant

```
docker exec attaquant bash -c "apt-get update && apt-get install -y
iputils-ping
curl"
```

```
brandon@debian:~/cybersec-audit-codemax$ docker exec attaquant curl --version
curl 7.88.1 (x86_64-pc-linux-gnu) libcurl/7.88.1 OpenSSL/3.0.22 zlib/1.2.13 brotli/1.0.9 zstd/1.5.4 libidn2/2.3.3 libpsl
/0.21.2 (+libidn2/2.3.3) libssh2/1.10.0 nghttp2/1.52.0 librtmp/2.3 OpenLDAP/2.5.13
Release-Date: 2023-02-20, security patched: 7.88.1-10+deb12u15
Protocols: dict file ftp ftps gopher gophers http https imap imaps ldap ldaps mqtt pop3 pop3s rtmp rtsp scp sftp smb smb
s smtp smtps telnet tftp
Features: alt-svc AsynchDNS brotli GSS-API HSTS HTTP2 HTTPS-proxy IDN IPv6 Kerberos Largefile libz NTLM NTLM_WB PSL SPNE
GO SSL threadsafe TLS-SRP UnixSockets zstd
brandon@debian:~/cybersec-audit-codemax$
```

7. Prouver que l'attaquant atteint la cible

```
docker exec attaquant ping -c 3 10.40.0.10
```

```
brandon@debian:~/cybersec-audit-codemax$ docker exec attaquant ping -c 3 10.40.0.10
PING 10.40.0.10 (10.40.0.10) 56(84) bytes of data.
64 bytes from 10.40.0.10: icmp_seq=1 ttl=64 time=0.061 ms
64 bytes from 10.40.0.10: icmp_seq=2 ttl=64 time=0.099 ms
64 bytes from 10.40.0.10: icmp_seq=3 ttl=64 time=0.147 ms

--- 10.40.0.10 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2033ms
rtt min/avg/max/mdev = 0.061/0.102/0.147/0.035 ms
```

8. Confirmer que le service web DVWA répond

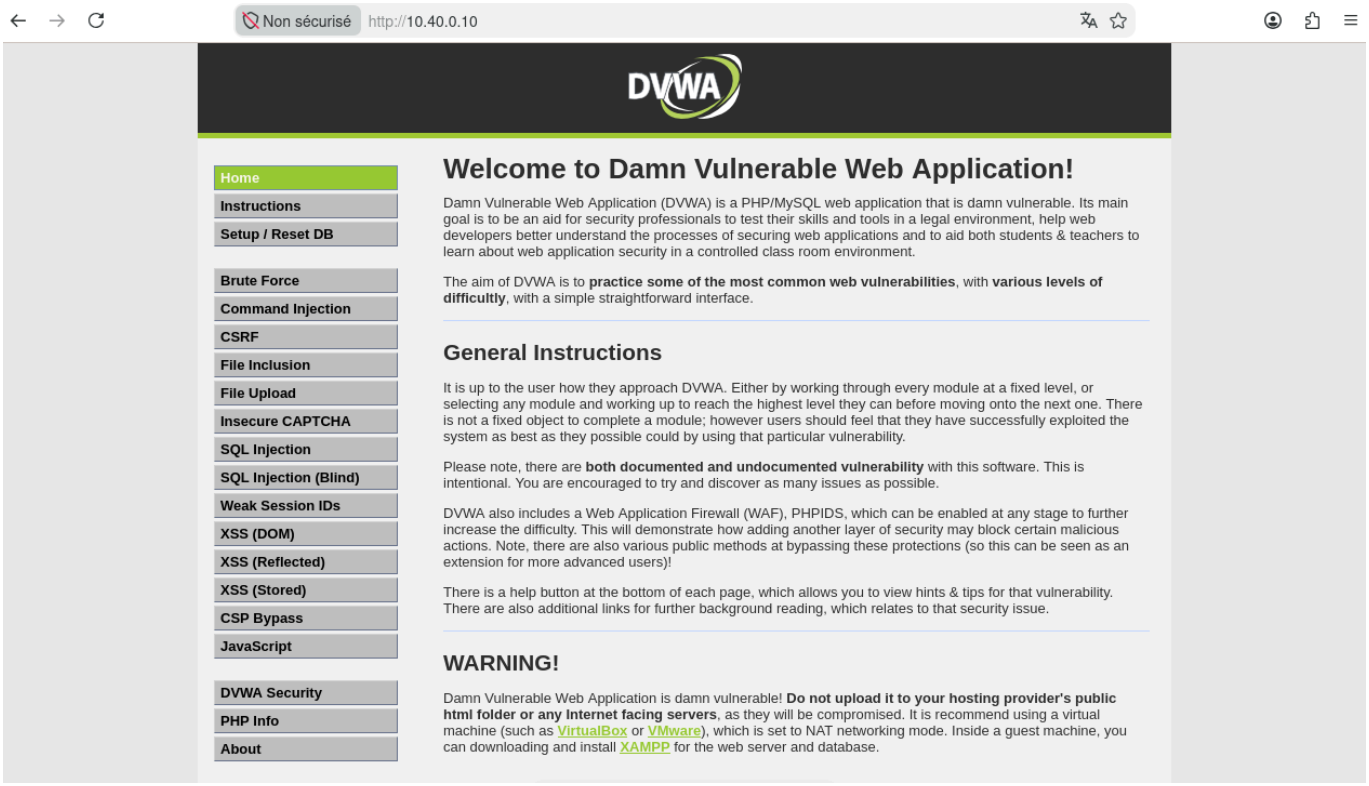
```
docker exec attaquant curl -s -o /dev/null -w "%{http_code}\n"
http://10.40.0.10/
```

```
brandon@debian:~/cybersec-audit-codemax$ docker exec attaquant curl -s -o /dev/null -w "%{http_code}\n" http://10.40.0.1
0/
302
brandon@debian:~/cybersec-audit-codemax$
```

9. Iinitialiser la BDD DVWA

```
docker exec attaquant sh -c "rm -f /tmp/ck; curl -s -c /tmp/ck
http://10.40.0.10/setup.php | grep -oE '[a-f0-9]{32}' | head -1 | xargs -I
TKN
curl -s -b /tmp/ck --data create_db=1 --data user_token=TKN
http://10.40.0.10/setup.php -o /dev/null; echo BASE_DVWA_PRETE"
```

10. Interface graphique de l'application web


Non sécurisé
http://10.40.0.10
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
Welcome to Damn Vulnerable Web Application!
Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers to learn about web application security in a controlled class room environment.
The aim of DVWA is to practice some of the most common web vulnerabilities, with various levels of difficultly, with a simple straightforward interface.
General Instructions
It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. There is not a fixed object to complete a module; however users should feel that they have successfully exploited the system as best as they possible could by using that particular vulnerability.
Please note, there are both documented and undocumented vulnerability with this software. This is intentional. You are encouraged to try and discover as many issues as possible.
DVWA also includes a Web Application Firewall (WAF), PHPIDS, which can be enabled at any stage to further increase the difficulty. This will demonstrate how adding another layer of security may block certain malicious actions. Note, there are also various public methods at bypassing these protections (so this can be seen as an extension for more advanced users)!
There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.
WARNING!
Damn Vulnerable Web Application is damn vulnerable! Do not upload it to your hosting provider's public html folder or any Internet facing servers, as they will be compromised. It is recommend using a virtual machine (such as VirtualBox or VMware), which is set to NAT networking mode. Inside a guest machine, you can downloading and install XAMPP for the web server and database.